QR-BASED ANTI-COUNTERFEITING FOR PERFUME PRODUCTS: A HYBRID ECDSA–SHA-256 AUTHENTICATION SYSTEM AND SECURITY EVALUATION

Mathiarassaan A/L Ramachanderan[1], Syarulnaziah Anawar[1], Zakiah Ayop[1], Wahidah Md Shah[1], Nur Fadzilah Othman[1]and Syahida Hassan[3]

[1]Fakulti Teknologi Maklumat dan Komunikasi, Universiti Teknikal Malaysia Melaka, Melaka, 76100, Malaysia
[2]Fakulti Kecerdasan Buatan Dan Keselamatan Siber, Universiti Teknikal Malaysia Melaka, Melaka, 76100, Malaysia
[3]UUM College of Art and Sciences. Universiti Utara Malaysia, Kedah, Malaysia

ABSTRACT

Counterfeit perfume products pose persistent economic and health risks, yet conventional safeguards such as holograms, batch codes, and printed serial numbers offer no cryptographic guarantee of authenticity and remain vulnerable to identifier reuse, whereby a genuine code copied from an authentic product can be applied undetected to a counterfeit. This paper designs, implements, and evaluates a QR-based authentication system that closes this structural gap by cryptographically binding each product's registration data to a manufacturer-held private key. Product metadata is hashed with SHA-256 and signed using the Elliptic Curve Digital Signature Algorithm (ECDSA) over the SECP256k1 curve; the signed payload is encoded into a QR code affixed to the packaging and verified through a login-free public portal and Android companion application. Black-box security evaluation using Burp Suite confirmed correct rejection of SQL injection and serial-number tampering across four test cases for both a hash-only baseline and the proposed hybrid system, achieving a 100% pass rate. Comparative analysis demonstrates that while both systems resist injection and tampering attacks equally at the ORM layer, only the proposed system prevents data forgery and identifier spoofing through asymmetric cryptographic signing, ensuring that a counterfeit QR code cannot be constructed without access to the manufacturer's private key. For manufacturers, this offers a low-infrastructure, deployable alternative to physical anti-counterfeit markers; for the research community, it provides an applied reference implementation of signature-based consumer product verification in a domain where such protection is not yet standard practice.

KEYWORDS

ECDSA, SHA-256, QR Code Authentication, Anti-Counterfeiting System, Luxury Goods Security, Supply Chain Integrity, Digital Signatures, SECP256k1

1. INTRODUCTION

Counterfeiting has become a pervasive threat across the luxury goods sector, and perfumes are among the most frequently imitated products. Global trade in counterfeit and pirated goods reached an estimated USD 467 billion in 2021 alone, with cosmetics and personal-care items remaining among the categories most exposed to this trade [1]. Beyond the direct financial harm to legitimate manufacturers, counterfeit fragrances have been found to contain unregulated or unsafe ingredients, including substances classified as probable human carcinogens, exposing

DOI:10.5121/ijwmn.2026.18501

consumers to genuine health risks [2]. Traditional anti-counterfeit measures, including holograms, tamper-evident seals, and printed serial numbers, were designed for a retail environment where physical inspection was the primary line of defence. In an increasingly online and cross-border supply chain, these measures have proven insufficient on their own.

The weakness shared by most existing schemes is structural rather than incidental: a hologram, batch code, or serial number is, at best, difficult to reproduce, but none of them are cryptographically bound to the specific product they accompany. Once a counterfeiter obtains or observes a genuine identifier, whether a printed code or a QR image, that identifier can typically be copied onto fraudulent packaging without detection, because verification amounts to confirming that the code exists in a database rather than confirming that the code was produced by the legitimate manufacturer.

This paper addresses that structural weakness by applying digital signatures, rather than static identifiers, as the basis of product verification. The proposed system generates a SHA-256 hash of each product's registration data and signs that hash with the Elliptic Curve Digital Signature Algorithm (ECDSA) over the SECP256k1 curve, using a private key held exclusively by the manufacturer. The signed data is encoded into a QR code affixed to the packaging, so that any attempt to reuse or alter the underlying product data invalidates the signature and is flagged during verification, even where a genuine serial number has been copied.

The study is guided by four objectives: (i) to examine how cryptographic algorithms can be applied to consumer product verification; (ii) to design and implement a verification method that combines SHA-256 hashing with ECDSA signing; (iii) to evaluate the resulting system's data-integrity assurance, tamper-detection accuracy, and usability from an end-user perspective; and (iv) to deliver an online verification workflow that requires no user account or login, so as to minimise friction for consumers.

The remainder of this paper is organised as follows. Section 2 reviews existing perfume authentication practices and compares candidate cryptographic techniques. Section 3 describes the system architecture, development methodology, and test design. Section 4 reports the results of the security evaluation. Section 5 discusses these results in relation to existing practice, and Sections 6 and 7 present the conclusion and a combined discussion of the study's limitations and future research directions.

2. LITERATURE REVIEW

2.1. QR Codes and Digital Signatures in Product Verification

QR codes are widely adopted in logistics, retail, and product verification because they can store a meaningful amount of data and can be read with any modern smartphone camera. Their use in authentication, however, has typically been limited to linking a scan event to a backend database record; the code itself carries no cryptographic guarantee, and Rinkalkumar et al. [3] note that this leaves QR-based systems dependent on the security of the backend rather than the code itself. Digital signatures address this gap by allowing a recipient to verify, using only a public key, that a given message was produced by the holder of the corresponding private key and has not been altered since signing [4]. Asymmetric schemes such as RSA [5] and ECDSA [7] are the most widely deployed instantiations of this idea, and general treatments of their security properties are available in standard references [6], [8].

A formal standard for embedding digital signatures directly within automatic identification data carriers, including barcodes and RFID tags, already exists in ISO/IEC 20248 [9], which defines a structured, certificate-based signing and verification scheme intended for offline use. The system proposed here applies the same underlying principle in a simplified, application-specific form suited to online, QR-mediated consumer verification, rather than the general-purpose offline framework the standard specifies. It is also worth noting that QR codes carry security risks independent of their payload's cryptographic protection, since the printed code itself can be physically substituted or used to redirect users to malicious destinations [10]; this risk is discussed further in Section 7.

2.2. Authentication Practices among Major Perfume Brands

To situate the proposed system relative to current industry practice, Table 1 summarises the authentication methods disclosed or observed for five major perfume brands, together with their principal limitation and the gap addressed by the proposed hybrid approach. The source consulted for each brand's practice is cited alongside its authentication method.

Table 1. Comparison of Existing Brand Authentication Methods and the Proposed System

Brand	**Authentication Method**	**Principal Limitation**	**Gap Addressed by Proposed System**
Chanel	Batch codes and holograms [11]	Codes can be reused or peeled; not cryptographically linked to product data	Cryptographic signing makes even minor data changes detectable through signature mismatch
Dior	Serial numbers and ink stamp [11]	Verification is static and manual, and does not detect tampering	Provides an online, tamper-evident check based on public-key cryptography
Gucci	Marketing QR codes and internal serial IDs [9],[12]	QR content is not bound to authenticity data and can be spoofed	Binds QR content to a digitally signed hash that cannot be forged without the private key
Tom Ford	Foil seals and batch codes [11]	Packaging can be duplicated with no backend cryptographic check	Signature verification remains valid even where packaging is visually cloned
Jo Malone	Printed batch code only [11]	Easily counterfeited; no tamper resistance	Digital signing gives each product a verifiable cryptographic identity

Across all five cases, verification is either manual, database-dependent, or entirely absent at the cryptographic level. None of the disclosed methods can distinguish a copied identifier from a genuine one, which is precisely the weakness the proposed signature-based scheme is designed to close. Table1 are third-party observation guides rather than official brand disclosures, because major perfume manufacturers do not publish formal specifications of their anti-counterfeiting mechanisms. The analysis reflects the transparency gap that motivates this work. The table's purpose is narrow: to establish that no currently deployed system uses cryptographic origin verification. Consumer-facing sources are entirely sufficient to demonstrate that observable industry practice relies on holograms, batch codes, and serial numbers rather than digital signatures. The paper's contribution lies at the cryptographic architecture layer, not in the brand survey itself.

2.3. Comparative Evaluation of Cryptographic Verification Techniques

Beyond current brand practice, several cryptographic techniques could plausibly serve as the basis for QR-embedded product verification. Table 2 compares ECDSA against RSA-2048, the post-quantum scheme CRYSTALS-Dilithium (now standardised as ML-DSA), the symmetric HMAC-SHA256 construction, and a non-cryptographic QR-plus-database-lookup baseline of the kind evaluated by Devi et al. [13], across security strength, signature size, suitability for embedding in a QR code, and whether public verification is possible without a shared secret.

Table 2. Comparative Evaluation of Candidate Cryptographic Verification Techniques

Technique	**Security Strength**	**QR Suitability**	**Public Verification**	**Assessment**
ECDSA (SECP256k1)	High – elliptic-curve discrete-log hardness	Excellent (~64-byte signature)	Yes, via public key	Curve parameters defined in SEC 2 [14]; shown to sign substantially faster than RSA on constrained mobile hardware [17]
RSA-2048	Moderate–high – integer-factorisation hardness	Poor (~256-byte signature)	Yes, via public key	Secure but too large for compact QR embedding [5]
CRYSTALS-Dilithium	Very high – lattice-based, quantum-resistant	Unsuitable (~2.7 KB signature)	Yes, public-key based	Future-proof but impractical for lightweight QR deployment; standardised as ML-DSA in FIPS 204 [16]
HMAC-SHA256	High, contingent on secret-key security	Good (32-byte tag)	No, requires shared secret	Efficient internally but unsuitable for public, login-free verification; underlying hash defined in FIPS 180-4 [15]
QR + Database Lookup	Low – no cryptographic binding	High (no signature overhead)	No, requires live database access	Vulnerable to spoofing and identifier reuse [13]

This comparison indicates that ECDSA offers the most balanced profile for the present use case: signatures compact enough for standard QR codes, public verifiability without a shared secret, and adequate computational efficiency for both server-side signing and verification, consistent with independent benchmarks reporting substantially faster ECDSA signing than RSA on constrained mobile hardware [17]. RSA and CRYSTALS-Dilithium extend security in different directions, integer-factorisation hardness and post-quantum resistance respectively, but at a signature size that is difficult to reconcile with QR code capacity limits. HMAC-SHA256, while efficient, is unsuitable here precisely because it requires the verifier to hold a shared secret, which conflicts with the objective of open, login-free consumer verification. These considerations, rather than an exhaustive independent benchmarking exercise, motivate the selection of ECDSA (SECP256k1) combined with SHA-256 hashing as the cryptographic basis of the proposed system.

On the other hand, blockchain-based anti-counterfeiting systems offer an alternative approach: Bali et al. [18] and Saha et al. [19] demonstrated that distributed ledger architectures provide tamper-evident, decentralised provenance tracking with no single point of trust failure, offering compelling properties for complex multi-tier supply chains. However, these systems impose significant infrastructure investment, transaction latency, and operational expertise that render them inaccessible to smaller producers. The proposed system achieves cryptographic non-repudiation through ECDSA without requiring blockchain infrastructure, substantially lowering the adoption barrier without sacrificing the core anti-cloning security property.

In the perfume sector specifically, as evidenced by the brand authentication review in Section 2.2, the majority of commercially deployed verification methods rely on holographic labels, batch codes, or simple serial number databases [11], [12], where all of them are susceptible to physical reproduction or digital replication. The proposed system directly addresses this gap: by embedding a cryptographically unforgeable ECDSA signature within a consumer-scannable QR code, it bridges the divide between cryptographic advances and practical, login-free consumer-facing authentication.

3. METHODOLOGY

3.1. System Architecture

The system follows a three-tier architecture comprising a presentation layer, an application layer, and a data layer, as illustrated in Figure 1. The presentation layer provides two interfaces: an administrative dashboard for product registration and management, and a public verification portal reached by scanning a product's QR code. The application layer, built with Flask, performs SHA-256 hashing, ECDSA signing and verification, QR code generation, and enforcement of business rules such as serial-number uniqueness. The data layer, implemented in MySQL, stores product records together with their cryptographic signatures and public keys, alongside an audit log that records every product addition and deletion for accountability.

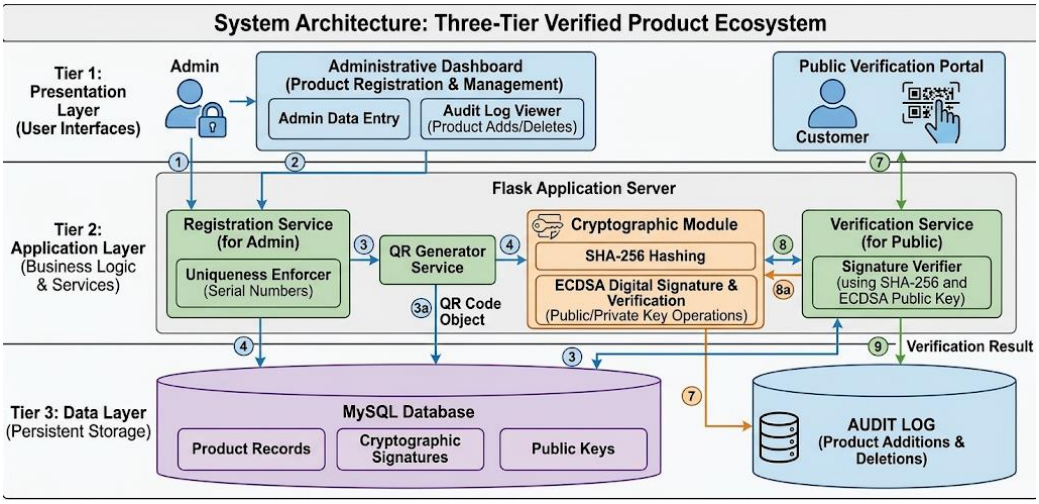


Figure 1. Three-tier system architecture of the perfume authentication platform.

3.2. Development Methodology

The system was developed using the Rapid Application Development (RAD) model, chosen for its emphasis on short, testable iterations. Development proceeded through requirements planning,

system analysis, interface and workflow design, iterative construction, continuous testing, deployment, and post-deployment review. This structure allowed the cryptographic core, hashing and signing, to be validated early, while the user interface and verification workflow were refined in subsequent cycles based on testing outcomes.

3.3. Cryptographic Verification Workflow

During registration, an administrator submits a product's brand, model name, volume, serial number, and manufacturing date. These fields are concatenated and hashed with SHA-256, as defined in FIPS 180-4 [15], to produce a fixed-length digest, which is then signed with the manufacturer's ECDSA private key (SECP256k1), using curve parameters defined in SEC 2 [14]. The resulting signature and the corresponding public key are stored alongside the product record, and a QR code is generated that directs to a verification endpoint referencing the product's identifier. When a consumer scans the code, the system retrieves the stored record, recomputes the SHA-256 hash of the product fields, and verifies the stored signature against that hash using the stored public key. A match confirms that the data has not been altered since registration and that it was signed by the holder of the corresponding private key; a mismatch, or the absence of a matching record, results in the product being flagged as invalid or not found. Figure 2 illustrates pseudocode for cryptographic QR code generation.

RegisterAndGenerateQR($Brand, Model, ML, SerialNum, MfgDate, SK_{admin}$)
Input: Product metadata ($Brand, Model, ML, SerialNum, MfgDate$), Private Key SK_{admin}
Output: $QRCode \in$ Image, $Status \in$ String

1. $\mathcal{M} \leftarrow Brand\mathbin{\|}Model\mathbin{\|}ML\mathbin{\|}SerialNum\mathbin{\|}MfgDate$
2. $H \leftarrow$ SHA-256($\mathcal{M}$)
3. $PK_{admin} \leftarrow$ DerivePublicKey(SK_{admin})
4. $\sigma \leftarrow$ ECDSASign(H, SK_{admin})
5. $Record \leftarrow (Brand, Model, ML, SerialNum, MfgDate, H, \sigma, PK_{admin})$
6. $ID_{prod} \leftarrow$ DatabaseInsert(ProductsTable, $Record$)
7. $URL_{verify} \leftarrow$ Concatenate("https://domain.com/verify/", ID_{prod})
8. $QRCode \leftarrow$ GenerateQR(URL_{verify})
9. **return** $QRCode$, "Product added and QR generated!"

Where:

- $Brand$: Name of perfume brand (string)
- $Model$: Perfume model/fragrance name (string)
- ML: Volume in milliliters (integer)
- $SerialNum$: Unique serial identifier (string)
- $MfgDate$: Manufacturing timestamp (date string)
- SK_{admin}: Admin's private key for digital signing (ECDSA key)

Figure 2. Pseudocode for Cryptographic QR Code Generation Using SHA-256 Hashing and ECDSA Signing

4. EXPERIMENTAL SETUP AND RESULTS

4.1. Test Environment Configuration

The experimental evaluation was conducted across two deployment environments. Initial validation was performed on a localhost environment hosted on a development workstation (Intel Core i5/i7, ≥2.5 GHz, 8–16 GB RAM) running Python 3.12, Flask, and MySQL, enabling granular monitoring of individual module behaviour and iterative debugging. Following successful local validation, the system was deployed to a cloud environment via Railway hosting to simulate real-world HTTP traffic. QR scanning was tested on an Android 10+ device via the Flutter companion application, and security attacks were conducted using Burp Suite v2025.7 on Kali Linux.

Prior to test execution, the database was populated with representative product records, ECDSA SECP256k1 key pairs were generated, and the mobile application was configured for scanning. Testing proceeded in four structured cycles: (1) two weeks of functional testing; (2) one week of integration testing; (3) one week of security testing via Burp Suite; and (4) one week of user acceptance testing.

4.2. Baseline and Proposed System Configurations

Two system configurations were evaluated under identical conditions. The **Basic System** employs SHA-256 hashing exclusively: upon QR code scanning, the verification endpoint recomputes the SHA-256 hash of the product serial number and compares it against the stored value in the MySQL database. While this mechanism detects modification of stored product data in transit, it provides no cryptographic proof of origin and offers no authentication in the formal sense: because SHA-256 is a public function requiring no key, any party can compute the hash of a known serial number and replicate a passing verification response. This approach represents a common pattern in deployed QR-based systems rather than a security alternative, and serves here as an illustrative baseline of current practice rather than a competing design.

The Proposed Systemaugments the SHA-256 baseline with the Elliptic Curve Digital Signature Algorithm (ECDSA) over the SECP256k1 curve. Each legitimate QR code is cryptographically signed at the point of generation using the manufacturer's private key. Verification intentionally requires only the public key, which is embedded in the application. This eliminates the need for consumer authentication, shared secrets, or server-side session management, and enabling login-free verification at scale without compromising security. During verification, the embedded signature is validated against the corresponding public key before any database query is executed. Any modification to product data or serial number invalidates the signature, and counterfeit codes lacking the private key cannot produce a verifiably authentic signature, directly addressing the data forgery vulnerability inherent to hash-only approaches.

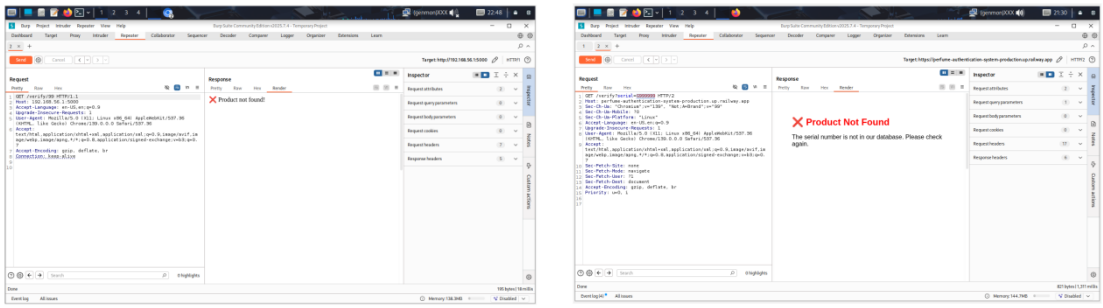
4.3. Test Design and Attack Methodology

A black-box testing methodology was adopted, evaluating each system solely on the basis of observable inputs and outputs without access to internal source code. The scope of this evaluation is explicitly the web application deployment layer, validating that the verification endpoint is not susceptible to common web-based attacks; it does not constitute a formal cryptographic evaluation of the ECDSA or SHA-256 primitives themselves, whose security properties are established in the cited standards literature. Security tests were executed using*Burp Suite Community Edition v2025.7.4* operating as an HTTP intercept proxy on a Kali Linux host.

Two attack vectors were evaluated. **SQL Injection (SQLi)** was simulated by appending the tautological payload *G123456' OR '1'='1* (URL-encoded as *G123456%27%20OR%20%271%27%3D%271*) to the verification endpoint URL as shown in Figure 3. **Serial Number Tampering** was evaluated by modifying a known-valid serial (G123456, corresponding to a registered Gucci Guilty 75 ml product, manufactured 2025-09-07) to a non-existent entry (G999999). The same real product record and synthetic attack payloads were applied to both systems. The full test specifications and outcomes are presented in Table 4, Figure 3, and Figure 4.

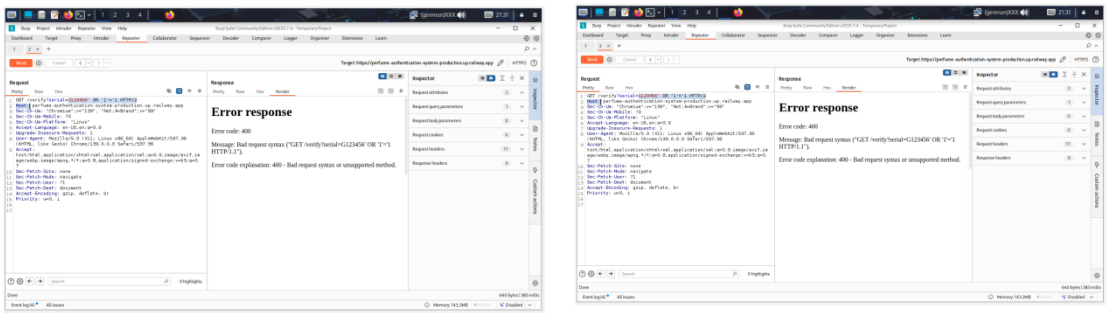
Table 4. Test Case Specification and Empirical Results

ID	System	Attack Vector	Expected Result	Actual Result	Status
TC-B1	Basic (SHA-256)	SQL Injection: /verify/G123456' OR '1'='1	Rejected — HTTP 404 Not Found	HTTP 404 Not Found	**PASS**
TC-B2	Basic (SHA-256)	Serial Tampering: G123456 → G999999	Product not found	Product not found	**PASS**
TC-P1	Proposed (ECDSA+SHA-256)	SQL Injection: /verify/G123456' OR '1'='1	Rejected — HTTP 400 Bad Request	HTTP 400 Bad Request	**PASS**
TC-P2	Proposed (ECDSA+SHA-256)	Serial Tampering: G123456 → G999999	Product not found + sig mismatch	Product not found	**PASS**



(a) Basic System (SHA-256 Only) *(b) Proposed System (ECDSA+SHA-256)*

Figure 3. Test Result of Serial Number Tampering



(a) Basic System (SHA-256 Only) *(b) Proposed System (ECDSA+SHA-256)*

Figure 4. Test Result of SQL Injection

4.4. Empirical Results

All four test cases achieved a PASS status across both systems, confirming that neither configuration exposes an exploitable SQL injection surface and that both correctly reject non-existent serial numbers. However, the mechanisms underlying these outcomes differ materially and carry distinct security implications.

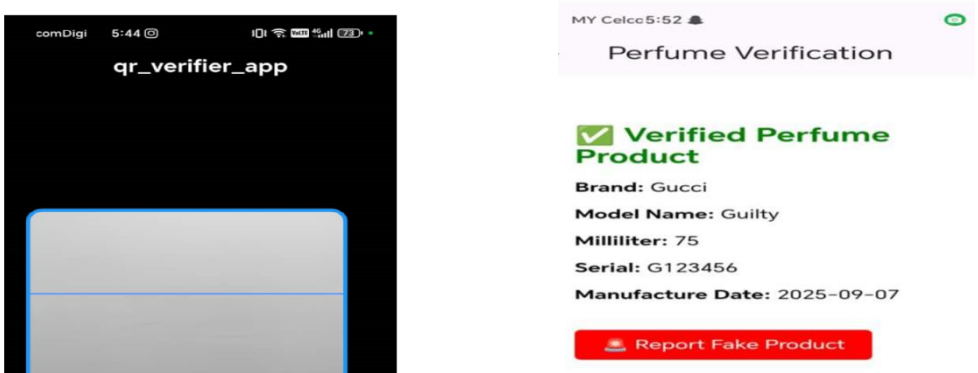
For the **Basic System** (TC-B1), the Flask routing layer treated the injected payload as a literal path string. The ORM-parameterised database query found no matching record and returned *HTTP 404 Not Found*. The injected characters were never interpreted as SQL syntax, indicating adequate passive input handling. In TC-B2, the absence of G999999 in the database triggered the same product-not-found response.

The **Proposed System** (TC-P1) returned *HTTP 400 Bad Request* with the explicit error message: "Bad request syntax ('GET /verify?serial=G123456' OR '1'='1' HTTP/1.1')." This response reflects active input validation at the application layer, prior to any routing or database interaction. In TC-P2, the system rejected the request both due to the absent database record and, critically, a failed ECDSA signature verification — even if the tampered serial had existed in the database, the absence of a valid signature would have caused rejection. A consolidated security capability comparison is presented in Table 5.

Table 5. Security Capability Comparison: Basic System vs. Proposed System

Security Criterion	**Basic System (SHA-256 Only)**	**Proposed System (ECDSA+SHA-256)**
SQL Injection Response	HTTP 404:passive (DB lookup miss)	HTTP 400: active request-level input rejection
Serial Tampering	Rejected via DB existence check	Rejected via DB check + ECDSA signature failure
QR Code Cloning	Vulnerable : valid serial reusable	Resistant to data forgery: private key required to construct valid code
Cryptographic Binding	Hash-only: SHA-256 integrity check	Asymmetric: ECDSA origin authentication + SHA-256 integrity
Forgery Prevention	No key-based proof of origin	Unforgeable without manufacturer private key
Error Semantics	Generic 404 for all invalid inputs	Specific 400 with descriptive error message
Deployment Suitability	Moderate — adequate for low-risk contexts	High — recommended for commercial anti-counterfeiting

Figure 3 presents the mobile application interface developed for consumer-facing product verification. The scanning screen (Figure 3a) displays the camera viewfinder with a blue scanning border, activated when the consumer taps the "Scan QR Code" button, requiring no prior account registration. Upon a successful scan of an authenticated product, the verification result screen (Figure 3b) displays the product details retrieved from the database alongside a green "Verified Perfume Product" confirmation, with all five registered fields presented for consumer inspection: brand, model name, volume, serial number, and manufacture date. A "Report Fake Product" button is also provided, enabling consumers to flag suspected counterfeits directly from the verification screen, supporting a broader consumer-driven fraud detection mechanism.



(a) QR code scanning interface *(b) Verification result for an authenticated product*

Figure 5. Mobile application interface showing the QR code scanning screen and the verification result for a successfully authenticated product.

5. DISCUSSION

5.1. Interpretation of Security Test Outcomes

Both systems achieved a 100% pass rate across all evaluated test cases, satisfying a baseline security threshold against SQL injection and serial tampering. This outcome is consistent with the established understanding that ORM-based database abstraction layers in Python-Flask environments inherently neutralise first-order SQLi vectors through parameterised query handling, as reflected in the architectural behaviour observed in TC-B1 and TC-P1. The critical distinction emerges when the threat model is extended to include data forgery and identifier spoofing, whereby a counterfeiter constructs a new QR code carrying a known serial number. Hash-based schemes are fundamentally open: any party can compute SHA-256 of a known string without any key, meaning a forged QR code carrying a copied serial number will pass hash verification on a spurious product. The ECDSA layer in the Proposed System closes this specific vulnerability through asymmetric cryptographic signing: a forged QR code cannot pass signature verification without the manufacturer's private key. It must be noted, however, that ECDSA prevents forgery, not physical duplication. If a counterfeiter photocopies or reprints an existing signed QR code without altering its data, the copied code will still verify as authentic, since the signature on the unmodified data remains mathematically valid. Preventing physical QR code duplication requires complementary physical measures, such as tamper-evident substrates, serialised holograms, or scan-count telemetry, which are outside the scope of the present system and are identified as directions for future work in Section 8.

5.2. HTTP Response Code Differentiation

A practically significant observation concerns the divergence in HTTP response codes between the two systems during SQL injection testing. The Basic System returned *HTTP 404 Not Found*, while the Proposed System returned *HTTP 400 Bad Request*. It is important to note that this

difference does not indicate that the Basic System is more vulnerable to SQL injection, where both systems block the attack equally at the ORM layer. Rather, the difference reflects how the two systems are architecturally structured. The Basic System routes the request to the database layer first, which passively returns a miss. On the contrary, the Proposed System applies explicit input validation at the request-handling stage before any further processing occurs, actively rejecting syntactically malformed inputs. This is consistent with OWASP Secure Coding Practices, which prescribe rejection of invalid inputs at the earliest processing stage. The structured 400 response also provides higher-fidelity signals for security monitoring and intrusion detection systems compared to generic 404 responses.

5.3. Comparison with Prior Studies

The integration of ECDSA with QR-based authentication reflects a broader trajectory in the literature toward asymmetric cryptographic primitives for supply-chain integrity. Prior work combining QR codes with RSA-based digital signatures has demonstrated that asymmetric schemes prevent counterfeit products from passing verification even when adversaries possess the genuine serial number. The present system replicates this property while selecting ECDSA over RSA: as Menezes, van Oorschot, and Vanstone [6] establish, ECDSA over a 256-bit curve achieves security equivalent to a 3072-bit RSA key while offering substantially reduced key size and computational overhead, a relevant consideration for mobile verification endpoints such as the Flutter-based client used here.

The comparison with the QR-plus-database-lookup baseline in Table 2, and with the one-time QR approach reported by Devi et al. [13], is informative here. A conventional QR-plus-database scheme is vulnerable precisely because verification asks only whether an identifier exists, not whether it was legitimately issued; the SQL injection test in Section 4 additionally shows that such lookups, if not carefully implemented, are themselves attackable at the query level. One-time QR codes mitigate identifier reuse by invalidating a code after its first scan, but this requires the system to track scan state and introduces its own usability trade-off, since a legitimate consumer who scans a product twice, for instance to re-check it before a sale, would encounter a false negative. The signature-based approach evaluated here avoids that trade-off: validity depends on cryptographic non-forgeability rather than on a one-time-use flag, so a genuine product can be verified repeatedly without being invalidated by its own legitimate use.

It is also worth noting that the security testing reported here evaluated the deployed system as a whole rather than the cryptographic scheme in isolation. The successful rejection of both attack classes reflects the combined effect of input validation at the application layer and signature verification at the cryptographic layer; the present study does not decompose these contributions, and a more granular evaluation, for example deliberately weakening input validation while leaving signature verification intact, would help clarify how much of the observed resistance is attributable to the cryptographic design specifically.

6. SIGNIFICANCE AND CONTRIBUTIONS

The results in Section 4 are best interpreted alongside the comparative analysis in Section 2. None of the brand practices summarised in Table 1 include a mechanism capable of distinguishing a genuine identifier from a copy of that identifier; a hologram or batch code, once observed, can be reproduced without any cryptographic penalty. The proposed system addresses this specific weakness: because the QR-embedded signature is a function of both the product data and a private key held only by the manufacturer, an attacker who copies a genuine serial number

onto counterfeit packaging cannot produce a signature that will verify against that data, and the tampering test in Section 4 illustrates this at the level of the verification endpoint.

Taken together, these findings support the central contribution of this work: a demonstration, grounded in a working implementation rather than a purely theoretical design, that binding product data to a digital signature closes a data-forgery gap that persists across current industry practice and in simpler QR-based verification schemes. The novelty of this work does not reside in the cryptographic primitives themselves, since ECDSA and SHA-256 are well-established standards. Rather, it lies in three areas: (i) the domain-specific application of these primitives to perfume product authentication, a sector where, as Table 1 shows, no commercially deployed system currently provides cryptographic origin verification; (ii) the design of a login-free, consumer-facing verification workflow that requires no shared secret, no account registration, and no proprietary scanning hardware; and (iii) the empirical comparison of a signature-based system against a hash-only baseline representative of current practice, establishing that the ECDSA layer prevents data forgery and identifier spoofing in a deployed web and mobile environment. The system deliberately does not claim to solve physical anti-counterfeiting, which involves tamper-evident packaging, supply chain provenance, and physical forensics beyond the scope of a digital signature scheme.

7. CONCLUSION

This study set out to investigate, design, and evaluate a cryptographic approach to perfume product authentication, guided by four objectives. The first, investigating the applicability of cryptographic algorithms to consumer product verification, was addressed through the comparative analysis in Section 2, which identified ECDSA combined with SHA-256 as a suitable balance of security, signature size, and QR compatibility. The second, combining digital signatures with ECDSA into a working verification method, was met through the system described in Section 3, in which product data is hashed, signed, and embedded into a QR code at registration, then re-verified at the point of consumer scanning. The third, evaluating data-integrity assurance, tamper-detection accuracy, and usability, was addressed through the black-box security testing reported in Section 4, which confirmed correct rejection of a SQL injection attempt and a tampered serial number, alongside informal observation of a smooth registration and verification workflow. The fourth, enabling online verification without a login requirement, was achieved through the public verification portal, which returns an authenticity result directly from a QR scan without requiring an account. Collectively, these results indicate that a hybrid ECDSA-SHA-256 approach is a technically viable and practically deployable alternative to the non-cryptographic authentication methods currently used across the perfume industry.

8. LIMITATIONS AND FUTURE RESEARCH DIRECTIONS

This study has several limitations that circumscribe the scope of its findings and identify directions for future work. First, and most fundamentally, the system addresses digital forgery prevention but not physical QR code duplication. ECDSA prevents a counterfeiter from constructing a new, valid QR code without the private key. However, it does not prevent exact physical reproduction. A counterfeiter who photocopies or reprints an existing signed QR code without altering its payload will produce a code that verifies as authentic, since the underlying signature remains mathematically valid. Preventing physical duplication requires complementary measures such as tamper-evident substrates, serialised holograms bonded to the QR label, or scan-count telemetry with velocity checks and geospatial anomaly detection, whereby repeated scans of the same serial number from geographically implausible locations within a short time window trigger a system alert.

Second, the security evaluation was limited in scope and depth. Testing covered only two attack vectors, SQL injection and serial-number tampering, applied to a single registered product record. Attack classes not evaluated include physical QR code cloning, replay attacks using a captured valid code, signature forgery attempts, denial-of-service scenarios targeting the verification endpoint, and private-key compromise and recovery. The use of Burp Suite to test for SQL injection constitutes web application security validation rather than a cryptographic evaluation; the security properties of ECDSA and SHA-256 are established in the cited standards literature and were not independently verified here. Future work should extend testing to a larger, more representative product dataset using formal penetration testing methodologies.

Third, no performance benchmarks were collected. Signing latency, verification time, QR generation overhead, and system throughput under concurrent load were not empirically measured. The system's stated performance targets were not validated. Related literature reports ECDSA signing substantially faster than RSA on constrained mobile hardware [17], supporting the plausibility of these targets, but direct measurement under realistic conditions remains necessary before deployment at scale. Longer-term directions include blockchain-based immutable audit trails for scan provenance [18], [19], migration to post-quantum signature schemes [16] as cryptographic standards evolve, and extension of the signing approach to other counterfeit-prone product categories such as pharmaceuticals and electronics.

ACKNOWLEDGMENT

We would like to thank Fakulti Teknologi Maklumat dan Komunikasi, Universiti Teknikal Malaysia Melaka (UTeM), for supporting the work done in this paper.

REFERENCES

[1] OECD/European Union Intellectual Property Office, Mapping Global Trade in Fakes 2025: Global Trends and Enforcement Challenges, Illicit Trade, OECD Publishing, Paris, 2025. https://doi.org/10.1787/94d3b29f-en.

[2] Federal Bureau of Investigation, “Counterfeit Cosmetics, Fragrances.” [Online]. Available: https://www.fbi.gov/news/stories/counterfeit-cosmetics-fragrances. [Accessed: Aug. 27, 2026].

[3] R.Rinkalkumar, K. Jadav and A. Somani, “A review on 1D & 2D barcode with QR code basic structure and characteristics,” International Journal of Futuristic Trends in Engineering and Technology, 2014.

[4] W. Diffie and M. E. Hellman, “New directions in cryptography,” IEEE Transactions on Information Theory, vol. 22, no. 6, pp. 644–654, 1976.

[5] R. L. Rivest, A. Shamir and L. Adleman, “A method for obtaining digital signatures and public-key cryptosystems,” Communications of the ACM, vol. 21, no. 2, pp. 120–126, 1978.

[6] A. J. Menezes, P. C. van Oorschot and S. A. Vanstone, Handbook of Applied Cryptography. CRC Press, 1996.

[7] S.-G. Liu, W.-Q. Chen and J.-L. Liu, “An efficient double parameter elliptic curve digital signature algorithm for blockchain,” in Proc. 2021 5th Int. Conf. on Cryptography, Security and Privacy (CSP), IEEE, 2021, pp. 83–88.

[8] B. Schneier, Applied Cryptography: Protocols, Algorithms, and Source Code in C. John Wiley & Sons, 1996.

[9] International Organization for Standardization / International Electrotechnical Commission, ISO/IEC 20248:2018 – Information technology – Automatic identification and data capture techniques – Data structures – Digital signature meta structure, 2018.

[10] K. Krombholz, P. Frühwirt, P. Kieseberg, I. Kapsalis, M. Huber and E. Weippl, “QR code security: A survey of attacks and challenges for usable security,” in Proc. Int. Conf. on Human Aspects of Information Security, Privacy, and Trust, Springer, 2014, pp. 79–88.

[11] CheckFresh.com, “Check the date of manufacture of perfumes and cosmetics.” [Online]. Available: https://www.checkfresh.com/. [Accessed: Aug. 27, 2026].

[12] QR Tiger, “5 Ways to Detect a Real and Fake Gucci Bag.” [Online]. Available: https://www.qrcode-tiger.com/gucci-qr-code. [Accessed: Aug. 27, 2026].
[13] P. J. Devi, M. S. Dutta, M. Damerakonda, D. N. Gutti and S. K. Domakuntla, “One time QR code for fake product identification,” in Proc. 2023 5th Int. Conf. on Inventive Research in Computing Applications (ICIRCA), IEEE, 2023, pp. 583–588.
[14] Certicom Research, SEC 2: Recommended Elliptic Curve Domain Parameters, Version 2.0, 2010. Available: https://www.secg.org/sec2-v2.pdf.
[15] National Institute of Standards and Technology, FIPS 180-4: Secure Hash Standard (SHS), U.S. Department of Commerce, Gaithersburg, MD, 2015.
[16] National Institute of Standards and Technology, FIPS 204: Module-Lattice-Based Digital Signature Standard, U.S. Department of Commerce, Gaithersburg, MD, 2024.
[17] M.Toorani and A. A. Beheshti, “LPKI – A lightweight public key infrastructure for the mobile environments,” in Proc. 11th IEEE Int. Conf. on Communication Systems (ICCS’08), 2008, pp. 162–166.
[18] A. Bali, A. Singh and S. Gupta, “Fake product detection system using blockchain,” presented at the Conference on Fake Product Detection Using Blockchain, Dec. 2022.
[19] S. Saha, K. R. Sarkar, R. Biswas, A. Biswas and R. Banik, “Blockchain driven authentication system for counterfeit product detection in supply chain,” International Journal of System Assurance Engineering and Management, 2026. https://doi.org/10.1007/s13198-026-03292-y.